Student Grade System Static Analysis

Issues and verification report

22 October 2026 | Lab 5 | Python 3.13.5

All 14 documented issue groups are fixed, including all six Bandit findings. The cleaned program retains the demo GPA of 4.35. This report records the problems in the assigned module, the fixes, and the evidence from rerunning the tools.

Tool results

Tool	Before	After
Pylint 4.1.3	5.51/10 22 messages	10.00/10 0 messages
Bandit 1.9.4	6 findings 2 high, 1 medium, 3 low	0 findings
Flake8 7.4.1	8 findings	0 findings

All final analyzer exit codes are 0. No findings were suppressed. Bandit reports zero skipped files and zero skipped security checks.

Issues table

Lines refer to the preserved original source. Bandit severities are taken from its report; other severities are review priorities. Manual findings are identified separately. Every row below has been addressed.

Issue	Type	Lines	Description	Fix Approach
Weak MD5 digest	High security Bandit B324	49	The student identifier is hashed using weak MD5.	Use SHA-256 with UTF-8 encoding. The digest identifies a record; it is not an authentication secret.
Shell command injection	High security Bandit B605	60	The export filename is concatenated into a shell command.	Remove os.system and print the confirmation directly. Treat the filename as a literal file path.
Arbitrary expression execution	Medium security Bandit B307 Pylint W0123	41-45	eval executes a supplied GPA expression as Python code.	Use arithmetic mean divided by a validated positive numeric scale. The default remains 20.0, giving GPA 4.35 in the demo.
Shared default list	Medium bug Pylint W0102	15-19	The default audit list is shared across function calls.	Default grade_list to None and create a fresh list when none is supplied. Preserve caller-provided audit lists.

Issue	Type	Lines	Description	Fix Approach
Input and empty-score handling	Medium bug Manual review	16, 25, 34, 42-44	Marks above 100 are accepted. Attendance has no bounds. Empty score lists cause division by zero.	Validate marks and attendance, return False for unknown students in boolean operations, and handle empty scores explicitly. Reject invalid GPA scales.
Import runs the demo	Medium behavior Manual review	75	Importing the module changes grades, prints output, and exports a file.	Protect main with an if __name__ == '__main__' guard so importing only defines the module.
Silently swallowed exceptions	Low security Bandit B110 W0702 E722	23-27	A bare except with pass hides unknown IDs and programming errors.	Replace the try block with explicit ID and input checks and return a success flag. Unexpected errors can propagate.
Predictable PIN source	Low security Bandit B311	53	random.randint is unsuitable for a registration credential.	Use secrets.randbelow(9000) + 1000 to preserve the four-digit range with a cryptographic random source.
Embedded and printed token	Low security Bandit B105	64, 72	A portal token is stored in source and printed in full. The print exposure is also a manual finding.	Read GRADE_PORTAL_TOKEN from the environment. Display only whether it is configured, never its value.
File resource handling	Low quality Pylint W1514 R1732	57-59	The file is manually closed and its text encoding is implicit.	Use a with statement and encoding='utf-8' so closing occurs even if writing fails.
Unused code	Low quality Pylint W0611 W0612 F401 F841	6, 31, 43	json and grace_marks are unused. eval hides the use of avg_score from the analyzers.	Remove the unused import and grace variable. Reference avg_score directly in the safe GPA calculation.
Missing docs and naming	Low style Pylint C0116 C0103	15-63	All eight public functions lack docstrings. addGrade does not follow snake_case.	Document each function and rename addGrade to add_grade, updating its demo call.
Comparison and control flow	Low style C0121 E711 R1703 R1705	32, 35-38	None is compared using ==, and a boolean result uses redundant branching.	Use is None and return the threshold comparison directly.
String and file formatting	Low style C0209 E501 C0304 W292	19, 34, 75	Old string formatting, lines over 79 characters, and a missing final newline reduce consistency.	Use an f-string, wrap long expressions, and end the cleaned source with a newline.

Behavior verification

All 10 regression tests passed. Coverage includes the original GPA and passing result, invalid marks, independent audit logs, attendance bounds, empty scores, unknown students, threshold boundaries, rejected GPA expressions, digest and PIN output, literal filenames containing shell syntax, hidden portal tokens, and imports without output or file side effects.

Compatibility changes

addGrade is now add_grade. compute_weighted_gpa takes a positive numeric scale instead of a Python expression. Marks retain equal weights and the default scale is 20.0, matching the original demo formula. Student identifier digests now use SHA-256.

Evidence files

The original is preserved in original/student_grade_system.py. Unedited analyzer output is in reports/before and reports/after. Each manifest.json records commands, versions, timestamps, source SHA-256 hashes and exit codes. The regression suite is test_student_grade_system.py. The editable issue table is also supplied as issues.md.

Repository

Fork URL supplied for this submission: https://github.com/gnprajwal/L5_42_student_grade_system

Scope

The analyzers scanned the assigned module. Zero findings do not establish complete application security. A deployed registration flow would still need limits on PIN attempts.